

Exposé

Master Thesis

Title

Enforcing Exclusive Domain-to-CA Binding in Firefox's PKI Architecture

At

Technische Universität Dresden
Faculty of Computer Science
Date: 13th October 2026

Name: Avadhoot Pravin Khedekar
Matriculation No: 5249247
Course: Distributed Systems Engineering
Email: avadhoot_pravin.khedekar@mailbox.tu-dresden.de

Table of Contents

1. Motivation....3
    1.1 Architectural Vulnerabilities in the Global X.509 PKIX Framework....3
    1.2 Structural Vulnerability in RFC 5280 Path Validation Traversal....3
    1.3 Protected Namespaces....4
    1.4 Absence of Hostname-Scoped Trust Policy Enforcement in Firefox....4
2. Technical Background....4
    2.1 Firefox PKI Subsystem Architecture....4
    2.2 Limitations of Existing Trust Administration....5
3. Proposed Solution....6
    3.1 High-Level Architecture....6
    3.2 Firefox Subsystem Integration....7
    3.3 Scope of Contribution....7
    3.4 Extension: Server Software Measurement Binding (RA-TLS)....7
4. Threat Model....8
5. Proposed Work Plan....8
6. Bibliography....9

1. Motivation

1.1 Architectural Vulnerabilities in the Global X.509 PKIX Framework

Modern web security relies on the X.509 Public Key Infrastructure (PKIX) defined by RFC 5280. Under this model, web browsers trust hundreds of pre-installed Certificate Authorities (CAs), each with unrestricted global authority [1]. Because any trusted CA can issue a valid certificate for any domain, web infrastructure faces two main problems:

1. **CA Misissuance and Key Compromise:** A compromised CA can issue unauthorized certificates for target websites, allowing attackers to carry out undetected Man-in-the-Middle (MitM) attacks [1].
2. **Enterprise TLS Interception:** Network middleboxes (such as corporate proxies) install local root certificates onto client devices to create synthetic certificates on the fly, breaking end-to-end transport security [2].

Existing standards do not solve this problem at runtime during the TLS connection. CAs check CAA records before issuing certificates, but browsers do not verify them when connecting to a site. X.509 Name Constraints can limit private CAs, but they cannot stop public CAs from issuing certificates for the same domain. Additionally, HTTP Public Key Pinning (HPKP) was deprecated across major browsers because it was complex to manage and caused site outage risks [4]. Also, domain owners managing sensitive subdomains (**protected namespaces**) have no standard way to enforce which specific CAs a client browser is allowed to trust.

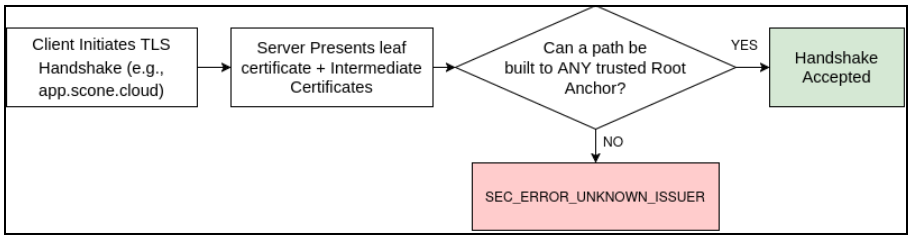


Figure 1: Baseline RFC 5280 path validation in Firefox. The handshake succeeds if any trusted root anchor validates the certificate chain.

1.2 Structural Vulnerability in RFC 5280 Path Validation Traversal

RFC 5280 defines certificate path validation based on a trust anchor and a valid certification path [3]. In the Web PKI, trusted CAs are generally able to issue certificates for arbitrary websites [1]. It does not check whether the domain owner authorized CA [1] [4]. As a result, any publicly trusted CA that can issue a valid certificate for a domain may authenticate it, making strict domain-specific trust boundaries difficult to enforce.

1.3 Protected Namespaces

To solve this problem, we use the concept of a Protected Namespace. A **Protected Namespace** is a sensitive domain hierarchy, such as *.scone.cloud, that requires stricter trust controls. Instead of trusting any public CA, the domain administrator specifies a set of approved CA keys, identified by their SPKI fingerprints [4]. Certificates issued by unauthorized CAs or enterprise proxies are therefore rejected for hosts within the protected namespace.

1.4 Absence of Hostname-Scoped Trust Policy Enforcement in Firefox

Firefox's certificate verification pipeline, based on PSM and mozilla::pkix, follows the standard Web PKI trust model [5]. Although Firefox provides enterprise policies and extension APIs, these mechanisms do not provide hostname-specific CA restrictions or required SPKI bindings [5]. Therefore, protecting a namespace against certificates issued by unauthorized CAs requires an extension to Firefox's certificate-verification architecture.

Research Question: How can Firefox be extended to support administrator-configured, hostname-specific trust-anchor policies that are enforced during TLS certificate verification?

2. Technical Background

2.1 Firefox PKI Subsystem Architecture

Firefox handles transport security through a modular architecture separating network transport, certificate path validation, and low-level cryptography [5]:

- **Personal Security Manager(PSM)**: PSM functions as the orchestrating middleware between Firefox's networking stack (Necko) and the path validation engine. When Necko establishes a TLS socket, PSM extracts target hostnames, configures verification parameters, and initiates path building [5].
- **Certificate Verification (CertVerifier):** *CertVerifier* coordinates the certificate verification process. It invokes mozilla::pkix to build and validate the certificate chain and performs additional checks, including verifying that the server certificate matches the requested hostname.
- **mozilla::pkix Path Validation:** The mozilla::pkix engine builds a certification path from the server's certificate through any intermediate CA certificates to a trusted trust anchor. It validates the chain according to certificate path-validation rules, including certificate

signatures, validity periods, and constraints. If multiple valid paths are possible, path building may consider alternative chains and trust anchors.

- **Network Security Services (NSS)**: The underlying cryptographic C library managing key stores (cert9.db) and executing low-level primitives (RSA/ECDSA signatures, SHA hashing) [5]. NSS is policy-agnostic and does not evaluate hostname-scoped trust logic.

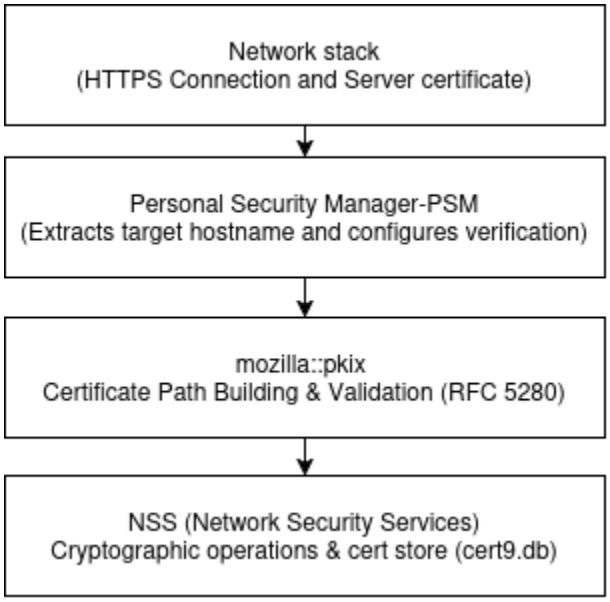


Figure 2: Firefox Certificate Verification

2.2 Limitations of Existing Trust Administration

Current enterprise configuration tools and previous user-agent security controls do not provide dynamic, per-hostname trust store isolation [2][4]:

- **Global Enterprise Root Scope (security.enterprise_roots.enabled):** Allows Firefox to import root certificates from the host OS [5]. However, these roots gain global trust for any website rather than being restricted to specific enterprise domains [2].
- **Firefox Enterprise Policy Schema (policies.json):** Allows installing custom roots (Certificates -> Install), but lacks any directive to restrict a target domain to a specific CA key. This leaves protected domains exposed if a public CA misissues a certificate [5][4].
- **Static Key Pinning (HPKP) Deprecation:** HTTP Public Key Pinning (RFC 7469) attempted key binding via HTTP headers, but had critical flaws. Pins were received post-handshake, leaving the initial connection vulnerable. Due to these operational risks, major browsers removed HPKP [3].

3. Proposed Solution

3.1 High-Level Architecture

The proposed solution introduces a hostname-scoped CA trust policy engine into Firefox to enforce exclusive bindings between protected domains and authorized Certificate Authorities (CAs). Under this model, an administrator-configured policy defines the set of CAs authorized to authenticate a target domain or subtree. For example, a policy may require that certificate chains for *.scone.cloud terminates at a specific CA identified by the SHA-256 fingerprint of its Subject Public Key Info (SPKI) [4].

The SPKI fingerprint does not need to be embedded in the X.509 certificate. Instead, during TLS certificate verification, Firefox obtains the SPKI of the relevant trust anchor, computes its SHA-256 fingerprint, and compares the result with the fingerprint specified by the administrator's policy. This allows the mechanism to operate with existing X.509 certificates and does not require changes to CA issuance procedures.

Enforcement occurs during client-side TLS certificate verification:

- **Protected Domains:** Firefox verifies that the certificate chain satisfies normal certificate validation and that its relevant trust anchor matches the CA specified by the domain-binding policy. Chains anchored at unauthorized CAs are rejected, even if they are otherwise valid under standard Web PKI validation [4].
- **Unprotected Domains:** Domains without an assigned policy continue to use the standard X.509/RFC 5280 certificate validation process [1] [5].

Conceptually, the verification pipeline is structured as follows:

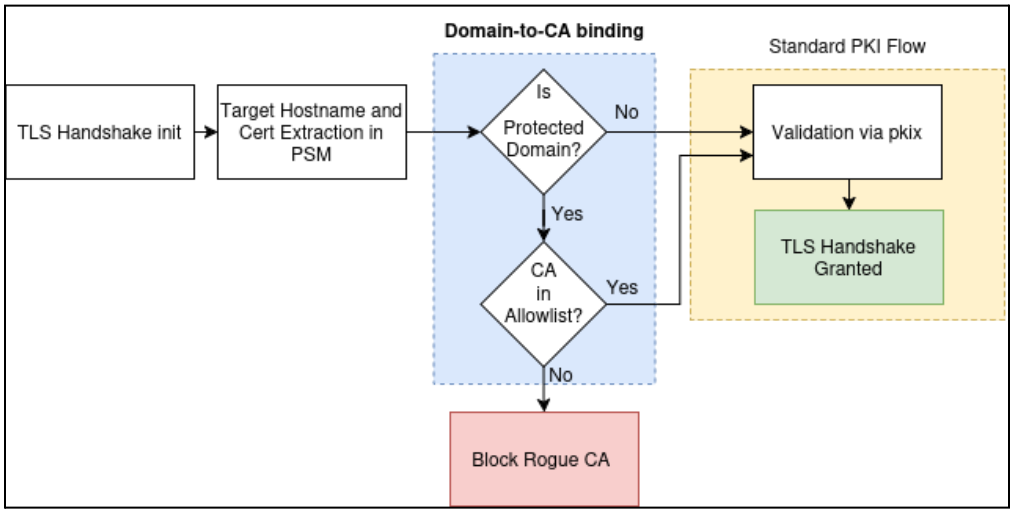


Figure 3: Proposed domain-to-CA binding workflow in Firefox. PSM enforces SPKI allowlist constraints on protected domains before path validation.

3.2 Firefox Subsystem Integration

The policy mechanism will be integrated into Firefox's existing C++ certificate-verification architecture. The precise enforcement point whether within the Personal Security Manager or the mozilla::pkix trust-anchor path-validation layer will be investigated and evaluated as part of the research.

The existing certificate path construction, constraint checking, and cryptographic verification mechanisms will remain responsible for standard certificate validation. As of now, the underlying Network Security Services (NSS) cryptographic primitives are not expected to require modification.

3.3 Scope of Contribution

The proposed browser-side policy operates independently of certificate issuance. While CAs issue certificates out-of-band, Firefox determines whether a CA is authorized to authenticate a particular protected hostname. The exclusive-binding guarantee therefore applies only to managed Firefox instances in which the policy is deployed and enforced, unmanaged or unmodified browsers continue to rely on standard Web PKI validation.

The security model assumes the following boundaries and out-of-scope items:

- **Local OS / Endpoint Compromise:** Host root/SYSTEM access, including policy-file tampering, browser binary modification, or memory manipulation, is considered out of scope.
- **Authorized CA Key Theft:** Compromise of an authorized CA's private key is outside the protection provided by the proposed domain-binding mechanism.

Inspired by Chromium's *Required Trust Anchors* framework [4], this research adapts hostname-specific CA binding to Firefox's C++ architecture. The core contribution is the design and evaluation of a mechanism for enforcing domain-specific trust-anchor restrictions while preserving standard Web PKI behavior for unprotected domains.

3.4 Extension: Server Software Measurement Binding (RA-TLS)

To complement transport-layer CA restrictions, the policy engine can be extended to verify the integrity of the software running on the server. Using Remote Attestation over TLS (RA-TLS), a secure server attaches a hardware-signed quote to its certificate during the TLS handshake [6]. This quote cryptographically links the server's public key to a hash of its running software binary.

Under this extended model, Firefox evaluates two complementary checks during certificate verification:

1. **Domain-to-CA Binding:** Confirms the certificate chain terminates at an approved CA key.
2. **Software Measurement Binding:** Confirms the server is running an authorized, untampered software binary.

If an attacker modifies the server software, the code hash changes, causing Firefox to fail verification and terminate the TLS handshake immediately. This extension bridges network transport security with server code integrity in confidential environments.

4. Threat Model

The threat model assumes an active network adversary capable of intercepting or re-routing TLS traffic. While the adversary does not possess the private key of the authorized CA, the system defends against 4 distinct attack vectors:

1. **Incorrect CA Issuance:** A public CA misissues an X.509 certificate for a protected domain (api.scone.cloud) to an unauthorized party [1].
2. **Enterprise TLS Interception:** Middleboxes or proxies generate synthetic certificates signed by custom injected local roots [2].
3. **Malicious Routing:** BGP/DNS hijacking routes client traffic to an adversary's server, forcing TLS validation against unapproved certificates.
4. **Cross-Signing & Path Substitution:** An adversary presents cross-signed intermediate certificates to force mozilla::pkix to construct an alternative valid path to an unapproved root [4].

5. Proposed Work Plan

Phase 1: Literature Review & Codebase Familiarization

Study existing approaches to certificate trust restrictions and domain binding, including Chromium's Required Trust Anchors proposal. Become familiar with Firefox's certificate-verification architecture and set up the development and testing environment.

Phase 2: Architecture & Policy Design

Design the hostname-specific trust-anchor policy and its representation in Firefox. Investigate the appropriate integration point within Firefox's certificate-verification architecture and define how hostname matching and SPKI-based trust-anchor identification will work.

Phase 3: Implementation

Implement the proposed policy mechanism in Firefox. This includes policy handling, hostname-specific trust-anchor matching, and integration with the existing certificate verification process while preserving standard Web PKI validation for unprotected domains.

Phase 4: Evaluation & Testing

Evaluate the implementation for correctness, security, and compatibility. Test protected and unprotected domains against the defined threat scenarios and measure any relevant performance overhead.

Phase 5: Analysis & Thesis Writing

Analyze the results, discuss the security properties, limitations, and compatibility of the approach, and consolidate the findings into the final thesis.

6. Bibliography

[1] [Durumeric et al., 2013]: *Analysis of the HTTPS Certificate Ecosystem* (ACM IMC 2013). Verified for global CA trust sprawl and additive path validation.

[2] [Durumeric et al., 2017]: *The Security Impact of HTTPS Interception* (NDSS 2017). Verified for enterprise middlebox interception, local root injection, and reduced connection security.

[3] [RFC 5280]: Cooper, D., Santesson, S., Farrell, S., Boeyen, S., Housley, R., & Polk, W. (2008). *Internet X.509 Public Key Infrastructure Certificate and Certificate Revocation List (CRL) Profile*. IETF RFC 5280.

[4] [Constrained Certificate Trust in Chrome]

[5] [Mozilla Documentation]: Verified accuracy regarding PSM (security/manager/ssl/), mozilla::pkix (security/pkix/), NSS, and policies.json.

[6] [Knauth et al., 2018] Knauth, T., Steiner, M., Chakrabarti, S., Lei, L., Xing, C., & Vij, M. (2018). *Integrating Remote Attestation with Transport Layer Security*.